W12D2 **10-3-2026**

Luca Danisi

VULNERABILITY ASSESsMENT

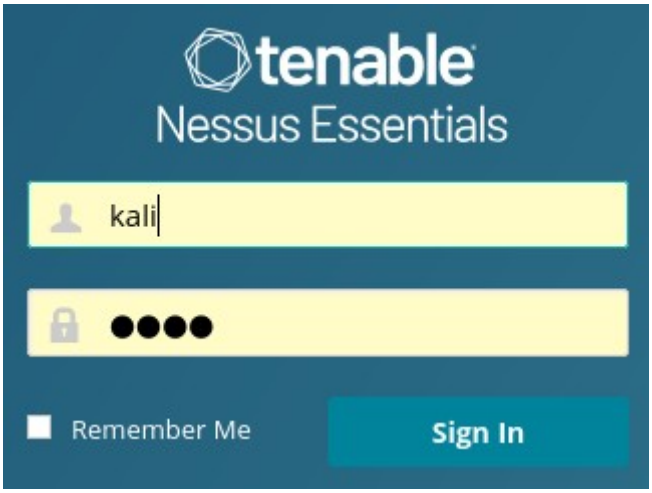
L esercizio di oggi prevede la scansione della macchina target **Metasploitable** (IP **192.168.50.101**) utilizzando un altra VM nel nostro caso **Kali** (IP **192.168.50.100**), entrambre configurate su rete interna. La scansione sarà effettuata utilizzando **Nessus** (installata su Kali).
Prima di iniziare l esercizio verificheremo che le macchine siano in grado di comunicare effettuando un comando PING.

```
┌──(kali㉿kali)-[~]
└─$ ping 192.168.50.101
PING 192.168.50.101 (192.168.50.101) 56(84) bytes of data.
64 bytes from 192.168.50.101: icmp_seq=1 ttl=64 time=6.87 ms
64 bytes from 192.168.50.101: icmp_seq=2 ttl=64 time=2.74 ms
64 bytes from 192.168.50.101: icmp_seq=3 ttl=64 time=2.59 ms
^C
--- 192.168.50.101 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2093ms
rtt min/avg/max/mdev = 2.589/4.066/6.873/1.985 ms
```

ESECUZIONE SCANSIONE

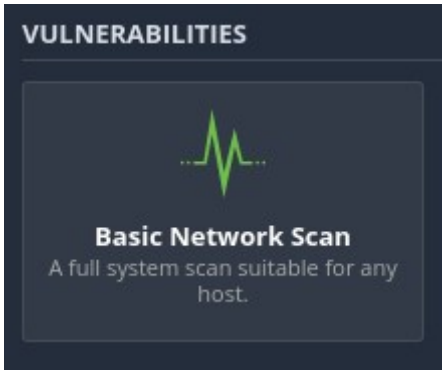
Nessus :

- Avviamo (dal terminale di kali) Nessus con il comando ***"sudo systemctl start nessusd"***
- *Apriamo il nostro browser di kali con l indirizzo* **"localhost:8834"** (8834, è la porta che nessus utilizza per la sua web interface).

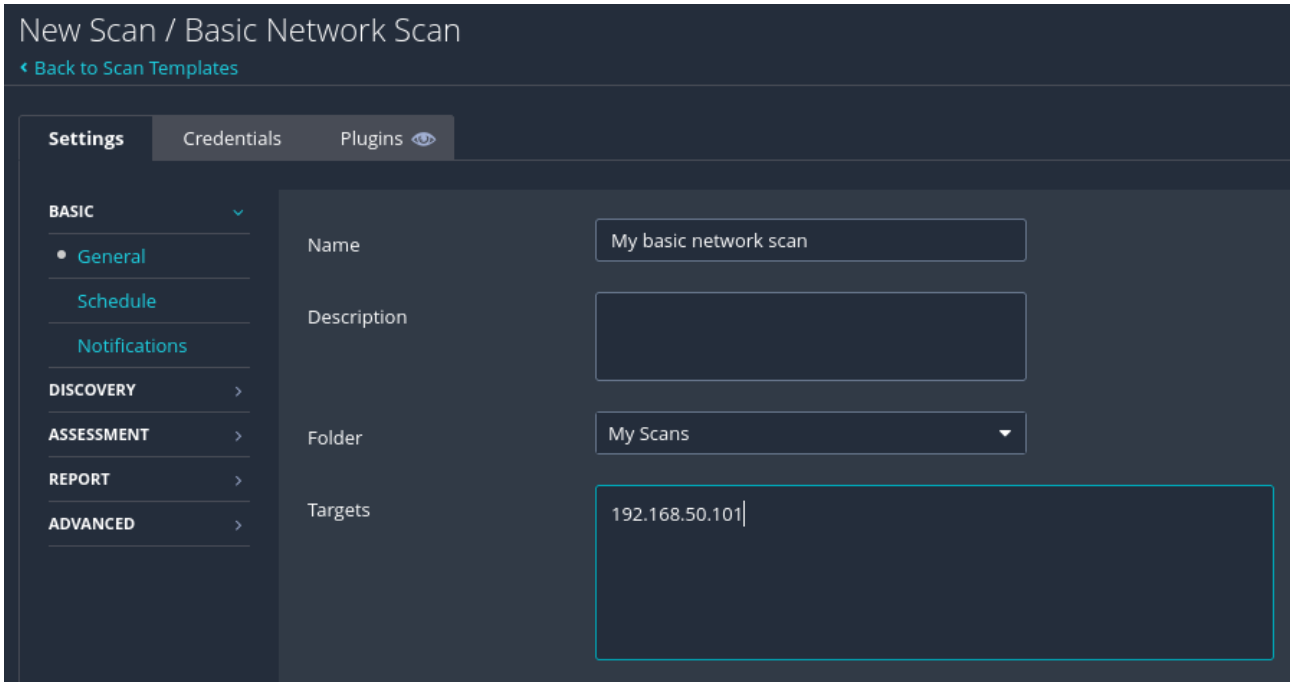


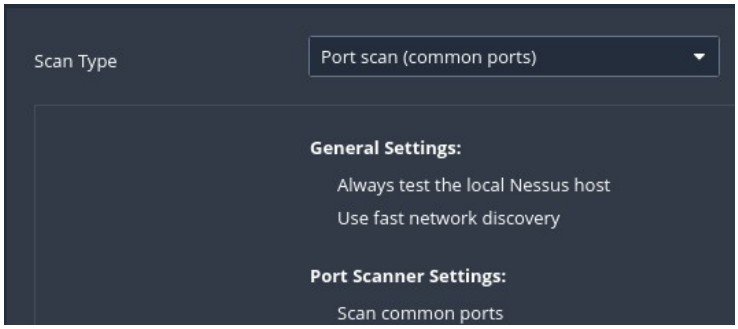
SCANSIONE

Dopo aver cliccato su **“new scan”** (nuova scansione), scegliamo dal menu delle vulnerabilities **“Basic Network scan”**



A Questo punto inseriamo nome e target IP della scansione.

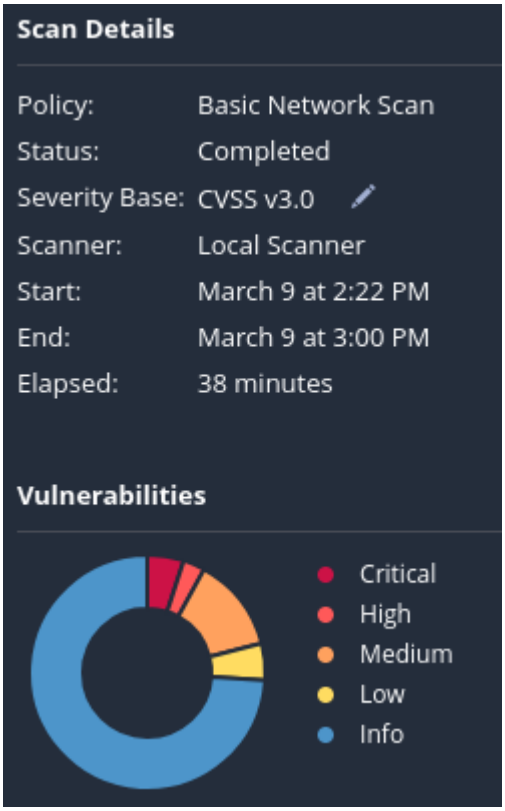




Come richiesto dall esercizio sceglieremo le **“common ports”**.

A questo punto possiamo avviare la nostra scansione

- **Target:** 192.168.50.101
- **Scanner:** Nessus Essentials su Kali
- **Durata scan:** 38 minuti
- **Rischio generale:** Alto/Critico
- **Principali problemi:** password debole, servizi vulnerabili, protocolli obsoleti, condivisioni permissive



Sev	CVSS	VPR	EPSS	Name
CRITICAL	10.0			Canonical Ubuntu Linux SEoL (8.04.x)
CRITICAL	10.0 *			VNC Server 'password' Password
CRITICAL	9.8	8.9	0.9447	Apache Tomcat AJP Connector Request Injection (Ghostcat)
CRITICAL	9.8			SSL Version 2 and 3 Protocol Detection
CRITICAL	9.8			Bind Shell Backdoor Detection
CRITICAL	...	...	...	SSL (Multiple Issues)
HIGH	7.5	5.9	0.7714	Samba Badlock Vulnerability
HIGH	7.5			NFS Shares World Readable

La scansione, e possiamo già notare che ci sono molte vulnerabilità considerate Critical e High , che saranno oggetto del approfondimento nel nostro report.

VULNERABILITA'

– PORT 80 : Canonical Ubuntu Linux SEoL (8.04.x)

IMPACT: According to its version, Canonical Ubuntu Linux is 8.04.x. It is, therefore, no longer maintained by its vendor or provider.

Lack of support implies that no new security patches for the product will be released by the vendor. As a result, it may contain security vulnerabilities.

SOLUTION :Upgrade to a version of Canonical Ubuntu Linux that is currently supported.

(Questa versione non è più supportata, e quindi risulta priva di aggiornamenti in grado di rimediare alle vulnerabilità - si consiglia un UPGRADE ad una versione corrente completa di periodici aggiornamenti)

- PORT 5900: VNC Server 'password' Password

IMPACT: the VNC server running on the remote host is secured with a weak password. Nessus was able to login using VNC authentication and a password of 'password'. A remote, unauthenticated attacker could exploit this to take control of the system.

SOLUTION :Secure the VNC service with a strong password.

(Cambiare la password con una più forte)

- PORT 8009 : Apache Tomcat AJP Connector Request Injection (Ghostcat)

IMPACT: a file read/inclusion vulnerability was found in AJP connector. A remote, unauthenticated attacker could exploit this vulnerability to read web application files from a vulnerable server. In instances where the vulnerable server allows file uploads, an attacker could upload malicious JavaServer Pages (JSP) code within a variety of file types and gain remote code execution (RCE).

SOLUTION : Update the AJP configuration to require authorization and/or upgrade the Tomcat server to 7.0.100, 8.5.51, 9.0.31 or later.

(aggiornare la versione di Tomcat,e richiedere un autorizzazione per accedere alle configurazioni)

- PORT 25 : SSL Version 2 and 3 Protocol Detection

IMPACT : The remote service accepts connections encrypted using SSL 2.0 and/or SSL 3.0. These versions of SSL are affected by several cryptographic flaws, including:

- An insecure padding scheme with CBC ciphers.

- Insecure session renegotiation and resumption schemes.

An attacker can exploit these flaws to conduct man-in-the-middle attacks or to decrypt communications between the affected service and clients.

Although SSL/TLS has a secure means for choosing the highest supported version of the protocol (so that these versions will be used only if the client or server support nothing better), many web browsers implement this in an unsafe way that allows an attacker to downgrade a connection (such as in POODLE). Therefore, it is recommended that these protocols be disabled entirely.

NIST has determined that SSL 3.0 is no longer acceptable for secure communications. As of the date of enforcement found in PCI DSS v3.1, any version of SSL will not meet the PCI SSC's definition of 'strong cryptography'.

SOLUTION : Consult the application's documentation to disable SSL 2.0 and 3.0.
Use TLS 1.2 (with approved cipher suites) or higher instead.

(I sistemi SSL 2.0 E 3.0, sono noti per avere numerose vulnerabilità, infatti si suggerisce la sostituzione con l utilizzo di TLS 1.2)

- PORT 1524 : Bind Shell Backdoor Detection

IMPACT : A shell is listening on the remote port without any authentication being required. An attacker may use it by connecting to the remote port and sending commands directly.

SOLUTION : Verify if the remote host has been compromised, and reinstall the system if necessary.

(L esistenza di una backdoor ovvero una shell in ascolto priva di autenticazione compromette tutto il sistema dando potenzialmente accesso a un attacker)

- PORT 445 : Samba Badlock Vulnerability

IMPACT : The version of Samba, a CIFS/SMB server for Linux and Unix, running on the remote host is affected by a flaw, known as Badlock, that exists in the Security Account Manager (SAM) and Local Security Authority (Domain Policy) (LSAD) protocols due to improper authentication level negotiation over Remote Procedure Call (RPC) channels. A man-in-the-middle attacker who is able to able to intercept the traffic between a client and a server hosting a SAM database can exploit this flaw to force a downgrade of the authentication level, which allows the execution of arbitrary Samba network calls in the context of the intercepted user, such as viewing or modifying sensitive security data in the Active Directory (AD) database or disabling critical services.

SOLUTION : Upgrade to Samba version 4.2.11 / 4.3.8 / 4.4.2 or later.

(Questa versione di Samba è nota sopratutto per dare la possibilità di eseguire un attacco “man in the middle” intercettando il traffico tra client e server. Si suggerisce un aggiornamento a versioni aggiornate almeno alla 4.4.2 o successive)

- PORT 2049 : NFS Shares World Readable

IMPACT : The remote NFS server is exporting one or more shares without restricting access (based on hostname, IP, or IP range).

SOLUTION : Place the appropriate restrictions on all NFS shares.

(Il network file sistem permette l accesso senza alcun tipo di restrizioni, si consiglia di modificare le impostazioni)

CONCLUSIONE

La scansione ha evidenziato diverse vulnerabilità critiche e alte sulla macchina Metasploitable, coerenti con la natura volutamente insicura del sistema. Le principali criticità riguardano servizi obsoleti, password deboli, protocolli insicuri e configurazioni troppo permissive. In un contesto reale, queste vulnerabilità richiederebbero prioritizzazione immediata e interventi di hardening, patching e segmentazione.